

 Table of Contents

1. The Four-Layer TCP/IP Model: Protocols, Data Flow & Security Implications

2. Encapsulation & Decapsulation: Headers, Trailers & Why Firewalls Care

3. Comparative Analysis: OSI vs. TCP/IP (Why Theory ≠ Reality)

4. SOC & VAPT Layer-by-Layer: Attacks, Tools & Defenses

1. The Four-Layer TCP/IP Model: Protocols, Data Flow & Security Implications

The **TCP/IP model** is the **practical backbone of the modern internet**, designed for **interoperability, scalability, and resilience**. Unlike the OSI model (which is theoretical), TCP/IP is **battle-tested** in real-world networks.

 TCP/IP Layer Breakdown

Layer	Name	Primary Function	Key Protocols	Data Unit	Hardware/Software Examples	Security Relevance
4	Application	End-user services & data formatting	HTTP/HTTPS, FTP, SMTP, POP3, IMAP, DNS, SSH, Telnet, SNMP, DHCP, NTP, RDP, SMB, LDAP, MQTT, CoAP, gRPC, WebSockets, SOAP, REST	Data (Payload)	Web servers (Nginx, Apache), Email servers (Postfix), DNS servers (BIND), Firewalls (Palo Alto, Fortinet), WAFs (ModSecurity, Cloudflare)	Attack Surface: SQLi, XSS, CSRF, SSRF, API abuse, DDoS. Defense: WAF, input validation, rate limiting.
3	Transport	End-to-end communication, reliability, multiplexing	TCP, UDP, SCTP, DCCP, QUIC	Segment (TCP), Datagram (UDP)	Load balancers (F5, NGINX), Stateful firewalls, IDS/IPS (Snort, Suricata)	Attack Surface: SYN floods, UDP floods, port scans, session

						hijacking. Defense: SYN cookies, rate limiting, stateful inspection.
2	Internet	Logical addressing & routing	IP (IPv4/IPv6), ICMP, IGMP, BGP, OSPF, EIGRP, RIP, IPsec, GRE, NAT	Packet	Routers (Cisco, Juniper), Layer 3 switches, Firewalls (with L3 filtering)	Attack Surface: IP spoofing, BGP hijacking, ICMP floods, fragmentatio n attacks. Defense: ACLs, uRPF, RPKI, firewalls.
1	Network Access	Physical & local network access	Ethernet (IEEE 802.3), Wi- Fi (IEEE 802.11), PPP, ARP, NDP, VLAN (802.1Q), STP (802.1D), MAC	Frame (L2), Bits (L1)	NICs, Switches, Hubs, Repeaters, Access Points (APs), Network TAPs	Attack Surface: ARP spoofing, MAC flooding, VLAN hopping, Evil Twin. Defense: Port security, DHCP snooping, 802.1X.

◆ Deep Dive: Data Flow Through TCP/IP Layers

Let's trace a **real-world example**: A user visits <https://example.com> in their browser.

Step 1: Application Layer (Layer 4)

- **User Action:** Types <https://example.com> → **DNS resolution** (if not cached).
- **DNS Request (UDP 53):**
 - **Application:** Browser sends **DNS query** for example.com.

- **Protocol: DNS (UDP).**
 - **Data:** DNS Query: A? example.com.
 - **Data Unit: DNS Message (Data).**
 - **HTTP Request (TCP 443):**
 - **Application:** Browser sends **HTTP GET request**.
 - **Protocol: HTTPS (HTTP over TLS).**
 - **Data:**
 - **Data Unit: HTTP Request (Data).**
 - **TLS Encryption:** If HTTPS, **TLS (Layer 6 in OSI)** encrypts the HTTP payload.
-

Step 2: Transport Layer (Layer 3)

- **Protocol Selection:**
 - **DNS:** Uses **UDP** (connectionless, low latency).
 - **HTTP:** Uses **TCP** (connection-oriented, reliable).
- **TCP Segment (for HTTP):**
 - **Source Port:** Ephemeral (e.g., 54321).
 - **Destination Port:** 443 (HTTPS).
 - **Sequence Number:** Random (for reliability).
 - **Acknowledgment Number:** 0 (initial SYN).
 - **Flags:** SYN (initiate connection).
 - **Window Size:** 65535 (flow control).
 - **Checksum:** Calculated for error detection.
 - **Payload:** **TLS-encrypted HTTP request**.
 - **Data Unit: TCP Segment.**
- **UDP Datagram (for DNS):**
 - **Source Port:** Ephemeral (e.g., 53535).
 - **Destination Port:** 53 (DNS).
 - **Length:** Size of DNS query.
 - **Checksum:** For error detection (optional in IPv4).
 - **Payload:** **DNS Query**.
 - **Data Unit: UDP Datagram.**

Step 3: Internet Layer (Layer 2)

- **IP Packet (for TCP/UDP):**
 - **Version:** 4 (IPv4) or 6 (IPv6).
 - **Header Length (IHL):** 5 (20 bytes for IPv4).
 - **Type of Service (ToS):** 0 (default).
 - **Total Length:** Size of IP packet (TCP/UDP + IP header).
 - **Identification:** Unique ID for fragmentation.
 - **Flags:** 0x40 (Don't Fragment) or 0x20 (More Fragments).
 - **Fragment Offset:** 0 (if not fragmented).
 - **Time to Live (TTL):** 64 (Linux) or 128 (Windows).
 - **Protocol:** 6 (TCP) or 17 (UDP).
 - **Source IP:** User's IP (e.g., 192.168.1.100).
 - **Destination IP:** 93.184.216.34 (example.com's IP).
 - **Checksum:** For header integrity.
 - **Payload:** TCP Segment or UDP Datagram.
 - **Data Unit:** IP Packet.

Step 4: Network Access Layer (Layer 1)

- **Ethernet Frame (IEEE 802.3):**
 - **Preamble:** 0xAAAAAAAA (synchronization).
 - **SFD (Start Frame Delimiter):** 0xAB.
 - **Destination MAC:** Next hop's MAC (e.g., 00:1A:2B:3C:4D:5E – router or switch).
 - **Source MAC:** User's NIC MAC (e.g., 00:1B:2C:3D:4E:5F).
 - **EtherType:** 0x0800 (IPv4) or 0x86DD (IPv6).
 - **Payload:** IP Packet.
 - **FCS (Frame Check Sequence):** CRC for error detection.
 - **Data Unit:** Ethernet Frame.
- **Physical Transmission (Bits):**
 - **Encoding:** Manchester, NRZ, or 4B/5B (for fiber).
 - **Medium:** Copper (twisted pair), Fiber, or Wi-Fi (radio waves).

- **Data Unit: Bits (0s and 1s).**

◆ Real-World Data Flow Example: HTTPS Request

Step	Layer	Action	Data Unit	Headers Added	Example Data
1	Application	Browser sends HTTPS request	Data	HTTP + TLS headers	GET / HTTP/1.1\nHost: example.com (encrypted)
2	Transport	TCP establishes connection (3-way handshake)	Segment	TCP header (SYN, ports, seq/ack)	TCP Segment: [TCP Header][TLS-Encrypted HTTP]
3	Internet	IP routes packet to destination	Packet	IP header (src/dst IP, TTL, protocol)	IP Packet: [IP Header][TCP Segment]
4	Network Access	Ethernet transmits frame to next hop	Frame	Ethernet header (src/dst MAC, EtherType) + FCS	Ethernet Frame: [Ethernet Header][IP Packet][FCS]
5	Physical	NIC converts frame to bits	Bits	None (raw bits)	01010101... (on the wire)

◆ Why This Matters for SOC & VAPT

- **SOC Perspective:**

- **Deep Packet Inspection (DPI)** relies on **parsing headers at each layer** (e.g., Wireshark, Zeek, Suricata).
- **Firewalls** filter based on **Layer 3 (IP) and Layer 4 (TCP/UDP ports)**.
- **SIEMs** correlate logs from **Layer 2 (MAC), Layer 3 (IP), Layer 4 (Ports), Layer 7 (Application)**.
- **NetFlow/sFlow** tracks **Layer 3/4 traffic** for anomaly detection.

- **VAPT Perspective:**

- **Nmap** scans **Layer 4 (ports)** and **Layer 7 (services)**.
 - **Wireshark/Scapy** craft packets at **any layer** (e.g., ARP spoofing (L2), IP spoofing (L3), SYN floods (L4)).
 - **Metasploit** exploits vulnerabilities at **Layer 7 (e.g., SQLi, RCE)** or **Layer 4 (e.g., TCP session hijacking)**.
 - **Etercap** performs **MITM at Layer 2 (ARP spoofing)**.
-

2. Encapsulation & Decapsulation: Headers, Trailers & Why Firewalls Care

Encapsulation = Adding headers (and sometimes trailers) as data moves **down** the stack.

Decapsulation = Removing headers/trailers as data moves **up** the stack.

This process is **critical for security** because:

- ✓ **Firewalls/IDS/IPS** inspect **headers at each layer** to detect attacks.
 - ✓ **SIEMs** correlate **log data** (e.g., **NetFlow for L3/L4, HTTP logs for L7**).
 - ✓ **Forensics** (e.g., **Wireshark, Zeek**) reconstructs **attack chains** by analyzing headers.
 - ✓ **DPI (Deep Packet Inspection)** relies on **parsing nested headers**.
-

◆ Encapsulation Process (Data Moving Down the Stack)

Let's follow a **HTTP GET request** from a browser to the wire.

1. Application Layer (TCP/IP Layer 4)

- **Data:** GET /index.html HTTP/1.1\nHost: example.com\n\n
- **Action:** HTTP formats the request.
- **Data Unit:** **HTTP Request (Data)**.
- **Headers Added:** **HTTP Headers** (Host:, User-Agent:, etc.).
- **If HTTPS:** **TLS encrypts the data** (adds **TLS Record Header**).

2. Transport Layer (TCP/IP Layer 3)

- **Protocol:** TCP (reliable) or UDP (unreliable).
- **Action:** Adds **TCP/UDP header**.
- **Data Unit:**
 - **TCP: Segment.**
 - **UDP: Datagram.**
- **Headers Added:**
 - **TCP:**
 - Source Port (e.g., 54321)
 - Destination Port (e.g., 443)
 - Sequence Number
 - Acknowledgment Number
 - Flags (SYN, ACK, FIN, RST, PSH, URG)
 - Window Size

- Checksum
- **UDP:**
 - Source Port
 - Destination Port
 - Length
 - Checksum (optional)

3. Internet Layer (TCP/IP Layer 2)

- **Protocol:** IP (IPv4 or IPv6).
- **Action:** Adds **IP header**.
- **Data Unit: Packet.**
- **Headers Added:**
 - Version (4 or 6)
 - Header Length (IHL)
 - Type of Service (ToS)
 - Total Length
 - Identification (for fragmentation)
 - Flags (Don't Fragment, More Fragments)
 - Fragment Offset
 - Time to Live (TTL)
 - Protocol (6 = TCP, 17 = UDP)
 - Source IP
 - Destination IP
 - Checksum

4. Network Access Layer (TCP/IP Layer 1)

- **Protocol:** Ethernet (IEEE 802.3), Wi-Fi (IEEE 802.11), PPP.
- **Action:** Adds **L2 header + trailer**.
- **Data Unit: Frame.**
- **Headers/Trailers Added:**
 - **Ethernet (IEEE 802.3):**
 - Preamble (0xAAAAAAAA)
 - SFD (0xAB)

- Destination MAC
- Source MAC
- EtherType (0x0800 for IPv4, 0x86DD for IPv6)
- **FCS (Frame Check Sequence)** (trailer, CRC for error detection)
- **Wi-Fi (IEEE 802.11):**
 - Frame Control
 - Duration
 - Address 1-4 (MAC addresses)
 - Sequence Control
 - **FCS** (trailer)

5. Physical Layer (OSI Layer 1)

- **Action:** Converts frame to **bits** for transmission.
- **Data Unit: Bits (0s and 1s).**
- **Encoding:** Manchester, NRZ, 4B/5B (for fiber).
- **Medium:** Copper, Fiber, Radio (Wi-Fi).

◆ Decapsulation Process (Data Moving Up the Stack)

When the **Ethernet frame** arrives at the destination, the process reverses:

Step	Layer	Action	Headers/Trailers Removed	Data Unit After
1	Physical	NIC receives bits	None	Bits
2	Network Access	NIC converts bits to frame	FCS (trailer)	Frame
3	Network Access	NIC checks FCS, strips L2 header	Ethernet header (MACs, EtherType)	IP Packet
4	Internet	OS checks IP header (TTL, checksum, dst IP)	IP header	TCP Segment / UDP Datagram
5	Transport	OS checks TCP/UDP header (ports, flags, checksum)	TCP/UDP header	Data (TLS-encrypted HTTP)
6	Application	App processes data (e.g., TLS decryption, HTTP parsing)	TLS header (if HTTPS), HTTP headers	Plaintext HTTP Request

◆ Headers & Footers: What Firewalls & Packet Inspectors See

Layer	Header/Trailer	Size (Bytes)	Key Fields for Security	Why It Matters
Application	HTTP Headers	Variable	Host:, User-Agent:, Cookie:, Authorization:	WAFs block malicious HTTP requests (e.g., SQLi, XSS). SIEMs detect unusual User-Agents (e.g., sqlmap).
Application	TLS Header	5	Content Type, Version, Length	DPI detects weak cipher suites (e.g., SSLv3, TLS 1.0). Firewalls block non-compliant TLS .
Transport	TCP Header	20-60	Source/Dest Port, Flags (SYN/ACK/FIN), Seq/Ack Numbers	Firewalls filter by port . IDS/IPS detect SYN floods (SYN without ACK) or session hijacking (predictable Seq/Ack) .
Transport	UDP Header	8	Source/Dest Port, Length, Checksum	Firewalls rate-limit UDP floods . DPI detects DNS amplification (UDP 53) .
Internet	IP Header	20-60	Source/Dest IP, TTL, Protocol, Flags (DF/MF)	Firewalls filter by IP . uRPF blocks IP spoofing . NetFlow tracks TTL anomalies (OS fingerprinting).
Network Access	Ethernet Header	14	Source/Dest MAC, EtherType	Switches forward based on MAC . Port Security blocks MAC flooding . ARPwatch detects ARP spoofing .
Network Access	Ethernet Trailer (FCS)	4	CRC (Cyclic Redundancy Check)	NICs drop corrupted frames . Wireshark flags FCS errors .

◆ Why This Mechanism is Crucial for Security Tools

Security Tool	Layers Inspected	What It Looks For	Example Use Case
Firewall (Layer 3/4)	Internet, Transport	IP addresses, ports, protocols, flags	Blocks IP spoofing , port scans , SYN floods .
WAF (Layer 7)	Application	HTTP headers, payloads, TLS versions	Blocks SQLi , XSS , CSRF , API abuse .

IDS/IPS (Snort, Suricata)	All layers	Signatures in headers/payloads	Detects Heartbleed (TLS) , EternalBlue (SMB) , ARP spoofing (L2) .
SIEM (Splunk, ELK)	All layers	Correlated logs (NetFlow, syslog, HTTP)	Detects multi-layer attacks (e.g., ARP spoofing + DNS tunneling).
NetFlow/sFlow	Internet, Transport	IP flows, ports, protocols	Detects DDoS , port scans , unusual traffic patterns .
Wireshark/Zeek	All layers	Full packet capture + deep analysis	Forensics for APT (Advanced Persistent Threats) .
Nmap	Transport, Application	Open ports, service versions, OS fingerprinting	Reconnaissance for vulnerability scanning .
Scapy	All layers	Custom packet crafting	Penetration testing (e.g., IP spoofing , TCP SYN floods).
Etercap	Network Access, Internet	ARP, IP, TCP	MITM attacks (e.g., ARP spoofing , session hijacking).

💡 Key Takeaway for SOC/VAPT

"Encapsulation is like a Russian nesting doll: Each layer adds its own header (and sometimes trailer), and firewalls/IDS/IPS peek inside each doll to find threats. VAPT tools craft malicious dolls, while SOC tools inspect them for anomalies."

3. Comparative Analysis: OSI vs. TCP/IP (Why Theory ≠ Reality)

◆ Layer Mapping: OSI vs. TCP/IP

TCP/IP Layer	OSI Layers	Protocols (TCP/IP)	Protocols (OSI)	Data Unit
4. Application	5. Session + 6. Presentation + 7. Application	HTTP, HTTPS, FTP, SMTP, DNS, SSH, Telnet, SNMP, DHCP, NTP, RDP, SMB, LDAP	HTTP, FTP, SMTP, X.400, X.500, ASN.1, MIME	Data
3. Transport	4. Transport	TCP, UDP, SCTP, DCCP, QUIC	TP0-TP4 (OSI Transport Protocols)	Segment (TCP), Datagram (UDP)

2. Internet	3. Network	IP (IPv4/IPv6), ICMP, IGMP, BGP, OSPF, RIP	CLNP (Connectionless Network Protocol), X.25	Packet
1. Network Access	1. Physical + 2. Data Link	Ethernet (802.3), Wi-Fi (802.11), PPP, ARP, NDP, VLAN (802.1Q), STP (802.1D)	X.21, HDLC, LAPB	Frame (L2), Bits (L1)

◆ Why the Industry Uses TCP/IP (Not OSI) in Practice

Reason	TCP/IP Advantage	OSI Limitation
First-Mover Advantage	ARPANET (1969) used TCP/IP before OSI was standardized (1984).	OSI was too late to compete.
Simplicity	4 layers are easier to implement and less redundant .	7 layers add unnecessary complexity for most use cases.
Flexibility	Layers can overlap (e.g., HTTP handles sessions, which OSI assigns to Layer 5).	Strict separation sometimes limits optimization .
Real-World Adoption	The entire Internet runs on TCP/IP.	No major network fully implemented OSI.
Performance	Faster due to less header overhead and flexible encapsulation .	Slower due to strict layer separation .
Government & Military Backing	DARPA (DoD) adopted TCP/IP early for ARPANET.	OSI was more academic and lacked real-world testing .
Vendor Support	Cisco, Juniper, Linux, Windows all support TCP/IP.	OSI's protocol suite (e.g., X.25, CLNP) was proprietary and less adopted .
Encapsulation Efficiency	Combines Layers 5-7 into Application , reducing overhead.	Session (L5) and Presentation (L6) are rarely used independently .
Protocol Suite	TCP/IP suite (e.g., TCP, IP, HTTP) is open and widely supported .	OSI suite (e.g., X.25, CLNP) was less practical .

"OSI is the theory; TCP/IP is the practice. Use OSI to learn and troubleshoot, and TCP/IP to build and secure."

Industry Preference for TCP/IP

OSI Model	TCP/IP Model	Why TCP/IP Won?
7 Layers	4 Layers	Simpler, more practical.
Strict Separation	Flexible Overlap	Allows optimization (e.g., TCP handles sessions + reliability).
Theoretical	Battle-Tested	**TCP/IP was used in ARPANET (1970s) before OSI (1984).
Vendor-Neutral	Vendor-Neutral	Both are open, but TCP/IP was first.
Not Fully Adopted	De Facto Standard	Internet runs on TCP/IP, not OSI.

◆ When to Use OSI vs. TCP/IP

Scenario	OSI Model	TCP/IP Model
Education	✔ Best for teaching networking concepts .	✗ Less detailed for layered learning .
Troubleshooting	✔ Helps isolate issues by layer .	✗ Lacks granularity for deep diagnostics.
Protocol Design	✔ Useful for defining new protocols .	✗ Less structured for R&D .
Real-World Deployment	✗ Rarely used as-is .	✔ De facto standard for the Internet.
Security Analysis	✔ Layer-by-layer attack mapping .	✗ Less precise for VAPT/SOC .

4. SOC & VAPT Application: Attacks, Tools & Defenses

Below is a **layer-by-layer breakdown** of attacks, VAPT techniques, SOC detection methods, and mitigations.

● Layer 1: Physical Layer (TCP/IP Network Access Layer)

Category	Common Attacks	VAPT Perspective (Exploitation)	SOC Perspective (Detection & Defense)	Mitigations
Physical Tampering	Cable tapping, RFID cloning, hardware keyloggers, Bad USB (Rubber Ducky), Evil Maid attacks	- Physical access to servers, routers, or user devices. - USB drop attacks (malicious USB drives). - RFID/NFC cloning (Proxmark3, ChameleonMini). - Hardware keyloggers (USB, PS/2).	- CCTV cameras (physical monitoring). - Tamper-evident seals on devices. - USB port locking (disabled ports, data blockers). - RFID/NFC logging (access control systems).	- Locked server racks/data centers (biometric access). - Faraday cages for sensitive equipment. - Disable unused ports (physical & USB). - HSMs (Hardware Security Modules).
RF Jamming	Wi-Fi jamming, Bluetooth jamming, Zigbee jamming, GPS jamming	- SDR (HackRF, LimeSDR, RTL-SDR) for signal disruption. - High-power RF amplifiers to overwhelm signals.	- Spectrum analyzers (Rohde & Schwarz, RF Explorer). - RF detection systems (CRFS RFeye). - Signal strength monitoring	- Frequency hopping (Bluetooth FHSS). - Spread spectrum techniques (DSSS, FHSS). - Redundant communication

			(Wireshark, Kismet).	paths (mesh networks).
TEMPEST (Emanations)	Van Eck phreaking, electromagnetic eavesdropping	- TEMPEST receivers to capture EM emissions from monitors/keyboards. - SDR-based eavesdropping (RTL-SDR + GNU Radio).	- EM shielding (Copper mesh, Mu-metal). - White noise generators to mask emissions. - Tempest-proof hardware (NSA-approved rooms).	- Faraday cages for sensitive devices. - Air-gapped systems for high-security environments.
Fiber Optic Tapping	Macrobending, fusion splicing attacks, OTDR exploitation	- Optical splitters to leak light from fiber. - Bending fiber cables to induce signal loss. - OTDR spoofing.	- Fiber optic intrusion detection (FOID) (DarkPulse, Senstar). - OTDR monitoring for unexpected signal loss.	- Fiber optic encryption (MACsec, IPsec). - Physical fiber path diversity (multiple routes).

Layer 2: Data Link Layer (TCP/IP Network Access Layer)

Category	Common Attacks	VAPT Perspective (Exploitation)	SOC Perspective (Detection & Defense)	Mitigations
ARP Attacks	ARP Spoofing/Poisoning, ARP Cache Poisoning	- arpspoof (dsniff suite) to poison ARP cache. - Ettercap for MITM attacks.	- Arpwatch (monitors ARP changes). - SolarWinds Kiwi Syslog	- Static ARP entries (prevents spoofing). - ARP Spoofing Detection

		- Scapy for custom ARP packets. - Bettercap for automated ARP spoofing.	(ARP table logs). - Zeek (Bro) IDS (detects ARP anomalies). - Switch logs (Syslog) for MAC-IP mismatches.	(Arpwatch alerts). - Port Security (Cisco: switchport port-security).
MAC Attacks	MAC Flooding, MAC Address Spoofing	- macof (dsniff suite) to flood CAM table. - Scapy to spoof MAC addresses. - Yersinia for Layer 2 attacks.	- Switch logs (Syslog) for CAM table overflows. - PRTG/Zabbix for MAC table monitoring. - Zeek (Bro) for MAC address anomalies.	- Port Security (limits MACs per port). - MAC Address Limiting (Cisco: switchport port-security maximum 1). - Disable unused ports.
VLAN Attacks	VLAN Hopping (Double Tagging, Switch Spoofing)	- Yersinia to exploit misconfigured trunk ports. - Scapy to craft 802.1Q tags. - Switch Spoofing (fake STP BPDUs).	- Switch logs (Syslog) for unexpected VLAN tags. - Zeek (Bro) for 802.1Q anomalies. - VLAN Access Control Lists (VACLs).	- Disable trunking on access ports (switchport mode access). - Use Private VLANs (PVLANS). - VLAN Hopping Protection (VLAN ACLs).
STP Attacks	STP Man-in-the-Middle, Root Bridge Election Manipulation	- Yersinia to manipulate STP. - Scapy to craft BPDUs. - Fake root bridge to intercept traffic.	- Switch logs (Syslog) for unexpected STP changes. - Zeek (Bro) for BPDU anomalies.	- BPDU Guard (Cisco: spanning-tree bpduguard enable). - Root Guard (prevents unauthorized root bridge).

				- Disable STP on edge ports.
DHCP Attacks	DHCP Starvation, Rogue DHCP Server	- Yersinia for DHCP starvation. - dhcpcd (ISC DHCP) for rogue DHCP server. - Metasploit (auxiliary/spoof/dhcp).	- DHCP Snooping (Cisco/Juniper). - Switch logs (Syslog) for unexpected DHCP requests. - Zeek (Bro) for DHCP anomalies.	- DHCP Snooping (trusted/untrusted ports). - Rate Limiting for DHCP requests. - IP Source Guard (prevents IP spoofing).
Wi-Fi Attacks	Evil Twin, Deauthentication, Karma Attack, Wi-Fi Pineapple	- hostapd-wpe for Evil Twin attacks. - airbase-ng for rogue APs. - MDK4 for deauthentication floods. - Scapy for custom Wi-Fi frames.	- Cisco Prime, Aruba AirWave (Wi-Fi monitoring). - Kismet for rogue AP detection. - Zeek (Bro) for Wi-Fi anomalies.	- WPA3-Enterprise (strong encryption). - MAC Address Randomization. - WIPS (Wireless Intrusion Prevention).
802.1X Attacks	EAP Downgrade, EAP-MD5 Cracking	- hostapd-wpe for EAP downgrade attacks. - FreeRADIUS-WPE for EAP exploitation. - Hashcat for EAP-MD5 cracking.	- FreeRADIUS logs for EAP anomalies. - Zeek (Bro) for 802.1X monitoring.	- EAP-TLS (certificate-based auth). - Protected EAP (PEAP).

● Layer 3: Network Layer (TCP/IP Internet Layer)

Category	Common Attacks	VAPT Perspective (Exploitation)	SOC Perspective (Detection & Defense)	Mitigations

IP Attacks	IP Spoofing, IP Fragmentation (Teardrop, Overlap)	- Scapy for IP spoofing. - Hping3 for fragmentation attacks. - Fragrouter for IP fragmentation testing.	- NetFlow/sFlow/PIFIX for spoofed IP detection. - Snort/Suricata for fragmentation anomalies. - uRPF (Unicast Reverse Path Forwarding).	- Ingress/Egress Filtering (BCP 38). - ACLs on Routers (block spoofed IPs). - Disable IP Fragmentation (if possible).
ICMP Attacks	Ping Flood, ICMP Redirect, ICMP Tunneling (Loki, ICMP Shell)	- Hping3 for ICMP floods. - Scapy for ICMP tunneling. - ICMPush for covert channels.	- Snort/Suricata for ICMP anomalies. - Zeek (Bro) for ICMP monitoring. - Firewall logs for unexpected ICMP types.	- Rate-Limiting ICMP (Cisco: no ip unreachable s). - Disable ICMP Redirects (Cisco: no ip redirects).
Routing Attacks	BGP Hijacking, OSPF Attacks, RIP Attacks	- ExaBGP for BGP hijacking. - GoBGP for BGP manipulation. - Scapy for OSPF/LSA flooding. - Quagga/FRRouting for route injection.	- BGPmon, RIPE RIS, Route Views for BGP monitoring. - Zeek (Bro) for OSPF/BGP anomalies. - NetFlow for unexpected route changes.	- RPKI (Resource Public Key Infrastructure). - BGP Prefix Filtering. - BGP TTL Security (GTSM). - OSPF Authentication (MD5, SHA).

IPv6 Attacks	RA Flooding, SLAAC Exploits, IPv6 Fragmentation	- THC-IPv6 Attack Toolkit. - Scapy for IPv6 crafting. - RA Flooding (CVE-2016-2118).	- Zeek (Bro) for IPv6 monitoring. - Wireshark for IPv6 anomalies. - NetFlow for IPv6 traffic analysis.	- RA Guard (Cisco). - Disable Unused IPv6 Transition Mechanisms. - IPv6 Firewall Rules.
NAT Attacks	NAT Bypass (Punching), UPnP Exploits	- STUN/TURN servers for NAT traversal. - UPnP Exploits (CVE-2013-0229). - Metasploit (auxiliary/scanner/upnp/ssdp_connect_back).	- Firewall logs for unexpected NAT entries. - NetFlow for UPnP anomalies.	- Disable UPnP (vulnerable to SSDP amplification). - Use Carrier-Grade NAT (CGN).

● Layer 4: Transport Layer (TCP/IP Transport Layer)

Category	Common Attacks	VAPT Perspective (Exploitation)	SOC Perspective (Detection & Defense)	Mitigations
TCP Attacks	SYN Flood, TCP Session Hijacking, TCP Reset (RST) Attacks	- Hping3 for SYN floods. - Scapy for TCP session hijacking. - Ettercap for MITM TCP attacks. - Metasploit (auxiliary/dos/tcp/synflood).	- NetFlow/sFlow/IFIX for SYN flood detection. - Snort/Suricata for TCP anomalies. - Zeek (Bro) for session hijacking detection.	- SYN Cookies (Linux: net.ipv4.tcp_syncookies = 1). - Rate Limiting (Cisco: ip tcp synwait-time 30). - Anycast Routing (Cloudflare, Akamai).

UDP Attacks	UDP Flood, UDP Reflection/Amplification (DNS, NTP, SNMP, SSDP)	- LOIC, HOIC for UDP floods. - DNS Amplification Scripts. - NTP Monlist Exploits. - SSDP Amplification (UPnP).	- NetFlow/sFlow/IFIX for UDP flood detection. - Snort/Suricata for UDP anomalies. - Zeek (Bro) for amplification attacks.	- Rate Limiting (Cisco: police). - Disable Unused UDP Services (SNMP, NTP, SSDP). - BGP Blackholing (RTBH).
Port Scanning	TCP SYN/Connect Scan, UDP Scan, SCTP Scan	- Nmap (-sS for SYN scan, -sU for UDP scan). - Masscan, Zmap for high-speed scanning. - Scapy for custom scans.	- Snort (sfPortscan preprocessor). - Zeek (Bro) for port scan detection. - OSSEC for brute-force detection.	- Firewall Rules (Palo Alto Threat Prevention). - Honeypots (Cowrie, Dionaea, CanaryTokens).
QUIC Attacks	QUIC Downgrade, QUIC Flood	- Mitmproxy for QUIC downgrade. - Scapy for QUIC flooding.	- Zeek (QUIC Plugin). - Wireshark (QUIC Dissector). - Cloudflare Logs for QUIC anomalies.	- DPI (Deep Packet Inspection). - Enforce TLS 1.3 (QUIC requires encryption).

● Layer 7: Application Layer (TCP/IP Application Layer)

Category	Common Attacks	VAPT Perspective (Exploitation)	SOC Perspective (Detection & Defense)	Mitigations
Web Attacks	SQL Injection (SQLi), Cross-Site	- SQLmap for SQLi automation. - Burp Suite, OWASP ZAP for	- WAF (ModSecurity, Imperva,	- Prepared Statements (PDO, ORM).

	Scripting (XSS), CSRF, SSRF	XSS/CSRF/SSRF. - Nuclei for vulnerability scanning.	Cloudflare). - SIEM (Splunk, ELK) for web attack detection. - Zeek (Bro) for HTTP anomalies.	- Input Validation (OWASP ESAPI). - CSP (Content Security Policy). - CSRF Tokens.
API Attacks	API Abuse, Excessive Data Exposure, Broken Authentication	- Postman, Burp Suite for API testing. - Nuclei for API vulnerability scanning. - OWASP ZAP for API security testing.	- API Gateways (Kong, Apigee, AWS API Gateway). - WAF (ModSecurity). - SIEM (Splunk, ELK) for API anomalies.	- Rate Limiting (NGINX, Cloudflare). - OAuth 2.0 / OpenID Connect. - JWT Best Practices (RS256, Short Expiry).
DNS Attacks	DNS Spoofing, Cache Poisoning (Kaminsky), DNS Amplification, DNS Tunneling	- dnscat2 for DNS tunneling. - Scapy for DNS spoofing. - Metasploit (auxiliary/spoof/dns/dns_amp).	- DNS Firewalls (Cisco Umbrella, Infoblox). - SIEM (Splunk, ELK) for DNS anomalies. - Zeek (Bro) for DNS monitoring.	- DNSSEC. - Response Rate Limiting (RRL). - Disable Open DNS Resolvers.
Email Attacks	Phishing, Spam, SMTP Spoofing, BEC	- Swaks, SendEmail for SMTP testing. - Social-Engineer Toolkit (SET). - Metasploit (auxiliary/client/smtp/enum_users).	- Email Gateways (Proofpoint, Mimecast). - Spam Filters (SpamAssassin).	- SPF, DKIM, DMARC. - Sandboxing.

			- Sandboxing (Cuckoo Sandbox, FireEye).	
FTP Attacks	Anonymous Login, Brute Force, Directory Listing	- Hydra for FTP brute force. - Nmap (ftp-* scripts). - Metasploit (auxiliary/scanner/ftp/ftp_login).	- Firewall Logs (Palo Alto, Fortinet). - Wireshark for FTP anomalies.	- Disable Anonymous FTP. - Use SFTP/SCP/FTP S.
JWT Attacks	JWT Forgery, Algorithm Confusion, Weak Secrets	- jwt_tool for JWT manipulation. - Burp Suite for JWT testing. - Hashcat for JWT secret cracking.	- WAF (ModSecurity) for JWT anomalies. - SIEM (Splunk, ELK) for JWT abuse detection.	- Use Strong Algorithms (RS256, ES256). - Short JWT Expiry. - JWT Blacklisting.
GraphQL Attacks	Introspection Abuse, Batch Queries, DoS	- GraphQL Cop for vulnerability scanning. - Burp Suite for GraphQL testing. - Postman for query crafting.	- API Gateways (Kong, Apigee). - WAF (ModSecurity). - SIEM (Splunk, ELK) for GraphQL anomalies.	- Disable Introspection in Production. - Query Depth Limiting. - Rate Limiting.
WebSocket Attacks	WebSocket Hijacking, DoS, XSS over WebSockets	- Burp Suite for WebSocket testing. - WebSocket King for fuzzing. - Scapy for custom WebSocket attacks.	- WAF (ModSecurity) for WebSocket anomalies. - SIEM (Splunk, ELK) for WebSocket abuse detection.	- Authenticate WebSocket Connections. - Rate Limiting. - Input Validation.

 SOC & VAPT Cheat Sheet: Attacks, Tools & Defenses by Layer

Layer	Common Attacks	VAPT Tools	SOC Detection Tools	Key Defenses
Physical	Cable tapping, RFID cloning, Bad USB, TEMPEST, Fiber tapping	Proxmark3, Hak5 Rubber Ducky, RTL-SDR, HackRF	CCTV, Tamper-evident seals, RF Spectrum Analyzers	Faraday cages, HSMs, Biometric access, Shielded cabling
Data Link (L2)	ARP Spoofing, MAC Flooding, VLAN Hopping, STP Attacks, DHCP Starvation, Evil Twin	arpspoof, macof, Yersinia, Ettercap, hostapd-wpe, Scapy	Arpwatch, Zeek, Switch Logs (Syslog), Kismet, SolarWinds Kiwi Syslog	Port Security, DHCP Snooping, STP Guard, 802.1X, WIPS
Network (L3)	IP Spoofing, BGP Hijacking, ICMP Flood, IP Fragmentation, IPv6 Attacks, NAT Bypass	Scapy, Hping3, ExaBGP, GoBGP, THC-IPv6, Fragrouter	NetFlow, sFlow, IPFIX, BGPmon, RIPE RIS, Zeek, Suricata	uRPF, RPKI, ACLs, Firewalls, BGP TTL Security, RA Guard
Transport (L4)	SYN Flood, UDP Flood, TCP Session Hijacking, Port Scanning, QUIC Downgrade	Hping3, LOIC, HOIC, Nmap, Masscan, Scapy, Mitmproxy	NetFlow, Snort, Suricata, Zeek, OSSEC	SYN Cookies, Rate Limiting, Stateful Firewalls, Anycast, DPI
Application (L7)	SQLi, XSS, CSRF, SSRF, API Abuse, DNS Spoofing, SMTP Spoofing, FTP Brute Force, JWT Attacks	SQLmap, Burp Suite, OWASP ZAP, Nuclei, dnscat2, Swaks, Hydra, jwt_tool	WAF (ModSecurity), SIEM (Splunk, ELK), Zeek, Email Gateways (Proofpoint), DNS Firewalls	Input Validation, CSP, CSRF Tokens, API Gateways, DNSSEC, SPF/DKIM/DMARC, SFTP/SCP

*"The TCP/IP model is the **highway**, the OSI model is the **map**. **SOC teams monitor the highway, VAPT teams find the potholes, and architects build the roads.**"*